

PrivacyAudit Italia S.r.l.

Valutazione d'Impatto sulla Protezione dei Dati

(DPIA — Art. 35 GDPR EU 679/2016)

Modulo Checkup — Piattaforma Resolv

Committente: Resolv S.r.l.

Data di emissione: 13 Marzo 2026

Versione: 1.0 — DOCUMENTO RISERVATO

Riferimento: PAI-2026-DPIA-001

Indice

1. Prefazione e Contesto della Valutazione

2. Descrizione del Trattamento

- 2.1 Natura del trattamento
- 2.2 Categorie di dati personali trattati
- 2.3 Soggetti interessati
- 2.4 Finalità e basi giuridiche
- 2.5 Flussi dei dati e infrastruttura tecnica

3. Necessità e Proporzionalità del Trattamento

- 3.1 Valutazione della necessità
- 3.2 Proporzionalità
- 3.3 Diritti degli interessati

4. Analisi dei Rischi

- 4.1 Metodologia
- 4.2 Registro dei rischi identificati
- 4.3 Riepilogo del livello di rischio residuo

5. Misure di Sicurezza Adottate

- 5.1 Autenticazione e controllo degli accessi
- 5.2 Cifratura dei dati
- 5.3 Sicurezza dei file e degli upload
- 5.4 Rate limiting e protezione endpoint
- 5.5 Audit log e monitoraggio
- 5.6 Conservazione e cancellazione automatica

6. Diritti degli Interessati (GDPR Art. 12-22)

7. Trasferimenti verso Terze Parti

8. Consultazione del DPO

9. Rischi Residui e Piano di Miglioramento

10. Conclusioni e Parere dell'Auditor

App. A Mappa delle Entità del Database

App. B Registro dei Trattamenti (estratto)

1. Prefazione e Contesto della Valutazione

Il presente documento costituisce la **Valutazione d'Impatto sulla Protezione dei Dati (DPIA)** redatta ai sensi dell'art. 35 del Regolamento (UE) 2016/679 (GDPR) con riferimento al **Modulo Checkup** integrato nella piattaforma software **Resolv**. La valutazione è stata commissionata da Resolv S.r.l. ed è condotta da **PrivacyAudit Italia S.r.l.**, società indipendente specializzata in audit di conformità alla normativa europea sulla protezione dei dati personali.

Perché la DPIA è obbligatoria

Il Modulo Checkup rientra nell'ambito applicativo dell'art. 35, par. 3, GDPR poiché soddisfa almeno due dei criteri indicati nelle Linee guida WP248 del Comitato europeo per la protezione dei dati (EDPB):

- **Trattamento su larga scala** di dati relativi a persone fisiche (aziende clienti e i loro referenti) nell'ambito di un servizio SaaS multitenancy con architettura a sublicenza.
- **Trattamento sistematico e profilazione**: il sistema raccoglie risposte strutturate a questionari di pre-valutazione (compliance, GDPR, sicurezza, organizzazione) che, aggregate, costituiscono un profilo di rischio aziendale dell'interessato.
- **Uso di tecnologie innovative**: cifratura a livello di colonna (AES-256-GCM), gestione di token crittografici, presenza real-time e audit trail automatizzato.

Titolo documento	DPIA — Modulo Checkup — Piattaforma Resolv
Riferimento interno	PAI-2026-DPIA-001
Versione	1.0
Data emissione	13 Marzo 2026
Committente	Resolv S.r.l.
Conduttore audit	PrivacyAudit Italia S.r.l.
Lead Auditor	Dott.ssa Francesca Conti, CIPP/E, CIPM
Periodo di analisi	Febbraio – Marzo 2026
Standard di riferimento	GDPR (EU) 679/2016, ISO/IEC 27001:2022, ENISA Threat Landscape 2024, Linee guida EDPB
Distribuzione	Resolv S.r.l. — Clienti Licenziatari (versione anonimizzata)

2. Descrizione del Trattamento

2.1 Natura del trattamento

Il Modulo Checkup è un'applicazione web SaaS (Software as a Service) in architettura multitenancy a tre livelli: **Resolv S.r.l.** (fornitore della piattaforma / Titolare del trattamento per il proprio personale interno), **Studi Licenziatari** (professionisti o strutture che acquistano la licenza e che operano come titolari autonomi o responsabili del trattamento nei confronti dei loro clienti) e **Clienti Finali** (persone fisiche o giuridiche che compilano i questionari di pre-valutazione).

Il modulo consente la raccolta, l'elaborazione, la conservazione e la comunicazione di dati relativi alla situazione organizzativa, di compliance e di sicurezza informatica delle aziende clienti, attraverso questionari strutturati e documenti allegati. I risultati alimentano report PDF automatici e validazioni multi-livello da parte degli operatori dello studio.

2.2 Categorie di dati personali trattati

A) Dati identificativi e di contatto degli utenti

- Nome, cognome, indirizzo e-mail, numero di telefono (CheckupUser)
- Ragione sociale, P.IVA, Codice Fiscale, indirizzo, sito web (CheckupClient / CheckupStudio)
- Credenziali di accesso: indirizzo e-mail + hash bcrypt della password
- Codici OTP per autenticazione a due fattori (2FA) — conservati in DB con TTL

B) Dati contenuti nel questionario di pre-valutazione (campo data — cifrato AES-256-GCM)

- Risposte a domande di pre-assessment su conformità GDPR, sicurezza IT, organizzazione interna, contrattualistica, processi aziendali
- Note testuali dell'operatore (notes, fieldNotes, userFieldNotes) — cifrate
- Metadati di compilazione: sezione, campo, timestamp, validazioni per macro-area
- Stato finale (concluso/in_progress), data di completamento, versione del questionario

C) Documenti allegati

- File caricati dall'utente (PDF, Word, Excel, PowerPoint, immagini, CSV) — max 30 MB
- Metadati: nome originale, tipo MIME, dimensione, SHA-256, ID utente che ha caricato, data
- Percorso fisico sul server (archiviazione locale /uploads/checkup-preassessment/)

D) Dati di comunicazione interna

- Messaggi di chat per sezione (CheckupPreassessmentMessage): testo libero, timestamp, ID utente
- Ticket di supporto (CheckupPreassessmentTicket): oggetto, corpo, cronologia stati, utente assegnatario
- Messaggi sui ticket (CheckupPreassessmentTicketMessage): testo libero
- Alert (CheckupPreassessmentAlert): messaggio, priorità, scadenza, utente destinatario

E) Dati tecnici e di audit

- Log di audit (CheckupAuditLog): azione, entità, userId, userEmail, userRole, indirizzo IP, user-agent, timestamp, esito
- Token JWT (access token 1h, refresh token 7gg via cookie httpOnly)
- Dati di presenza real-time (mappa in-memory): chi sta modificando quale campo

2.3 Soggetti interessati

Clienti finali (ruolo: cliente)	Persone fisiche o referenti di aziende che compilano i questionari di pre-valutazione. Categoria principale di interessati.
Staff dello studio (admin_studio, segreteria, collaboratore)	Professionisti del licenziatario che gestiscono il processo di assessment per conto dei propri clienti.
Amministratori di sistema (superadmin)	Operatori di Resolv S.r.l. con accesso trasversale per supporto tecnico e manutenzione.

2.4 Finalità e basi giuridiche

Finalità	Base giuridica (art. 6 GDPR)	Dettaglio
Erogazione del servizio di pre-assessment	Art. 6(1)(b) — Esecuzione del contratto	Il trattamento è necessario per l'adempimento del contratto tra lo studio licenziatario e il cliente finale
Autenticazione e sicurezza dell'accesso	Art. 6(1)(f) — Legittimo interesse	Protezione dell'integrità della piattaforma e prevenzione di accessi non autorizzati
Audit trail e tracciabilità operativa	Art. 6(1)(c) — Obbligo legale / Art. 6(1)(f)	Conformità a obblighi di sicurezza (art. 32 GDPR) e legittimo interesse alla tracciabilità degli accessi
Notifiche e comunicazioni interne (ticket, alert, e-mail 2FA)	Art. 6(1)(b) — Esecuzione del contratto	Strumentali all'erogazione del servizio e alla collaborazione tra studio e cliente
Gestione diritti degli interessati (export, cancellazione)	Art. 6(1)(c) — Obbligo legale	Adempimento degli obblighi GDPR art. 17 e 20

2.5 Flussi dei dati e infrastruttura tecnica

L'architettura tecnica prevede i seguenti componenti e flussi principali:

- **Frontend React (checkup-frontend):** applicazione SPA servita via HTTPS attraverso nginx (porta 8081). Nessun dato sensibile persistito nel browser eccetto l'access token JWT (localStorage) e il refresh token in cookie httpOnly.
- **Backend NestJS (apps/backend/src/checkup/):** API REST su porta 3000; validazione dei payload con class-validator; guard JWT + RBAC per ogni endpoint.
- **Database MySQL/MariaDB:** tabelle con prefisso checkup_; dati del questionario cifrati a livello di colonna (AES-256-GCM) tramite TypeORM transformer personalizzato.
- **Redis:** blacklist refresh token, challange 2FA, contatori di lockout, marcatura messaggi come letti (TTL 30 giorni).

- **File system locale:** upload in /uploads/checkup-preassessment/ (UUID filename); nessun CDN esterno identificato.
- **SMTP esterno:** invio codici 2FA, reset password, richieste cancellazione. Configurato tramite variabili d'ambiente (SMTP_HOST, SMTP_USER, ecc.).
- **Backup cifrati:** mysqldump con cifratura AES-256-GCM tramite CHECKUP_BACKUP_ENCRYPTION_KEY.

3. Necessità e Proporzionalità del Trattamento

3.1 Valutazione della necessità

L'analisi ha verificato che ciascuna categoria di dato trattato risponde a una specifica e documentata necessità funzionale:

Dati anagrafica utente (nome, email, tel.)	Necessari per identificare l'utente, inviargli comunicazioni di servizio e abilitare il processo di autenticazione 2FA.
Dati fiscali del cliente (P.IVA, CF)	Necessari per la corretta intestazione dei report e per l'identificazione univoca dell'entità giuridica soggetta a pre-valutazione.
Risposte al questionario (campo data)	Costituiscono il nucleo del servizio; non è possibile ridurre ulteriormente la raccolta senza pregiudicare la funzione di assessment.
Note operative (fieldNotes, notes)	Strumentali alla collaborazione tra staff e cliente; opportunamente cifrate e cancellate al termine del periodo di conservazione.
Documenti allegati	Richiesti dal processo di assessment per comprovare le risposte fornite; validati con magic bytes e SHA-256.
Audit log (IP, user-agent, azione)	Necessari per la sicurezza della piattaforma (art. 32 GDPR) e la ricostruzione degli eventi in caso di incidente.
Cookie refresh token httpOnly	Necessario per garantire la continuità della sessione senza esporre il token a script di pagina (mitigazione XSS).

3.2 Proporzionalità

Le seguenti misure dimostrano che il trattamento rispetta il principio di minimizzazione dei dati (art. 5(1)(c) GDPR) e di limitazione della conservazione (art. 5(1)(e)):

- I pre-assessment completati vengono **anonimizzati automaticamente dopo 365 giorni** (configurabile tramite CHECKUP_PREASSESSMENT_RETENTION_DAYS): i campi data, notes, fieldNotes, userFieldNotes, naFields, fieldMeta vengono azzerati.
- I **file fisici allegati** vengono eliminati dal disco contestualmente all'anonimizzazione.
- I **log di audit** vengono cancellati dopo 90 giorni (CHECKUP_AUDIT_RETENTION_DAYS).
- I **token Redis** (2FA challenge, refresh blacklist, lockout) hanno TTL automatici (5 minuti, 7 giorni, 15 minuti rispettivamente).
- La **mappa di presenza in-memory** è limitata a 10.000 preassessment, con cleanup ogni 5 minuti — nessuna persistenza su disco.
- L'indirizzo e-mail e il ruolo sono visibili agli amministratori del solo studio di appartenenza; i clienti non hanno accesso ai dati di altri clienti.

3.3 Diritti degli interessati — Implementazione tecnica

Il sistema implementa nativamente i seguenti diritti previsti dagli artt. 12-22 GDPR:

Diritto (GDPR)	Stato	Implementazione tecnica
Accesso (art. 15)	✓ Implementato	GET /checkup/me/export — download JSON con tutti i dati personali (rate limit: 5/ora)
Portabilità (art. 20)	✓ Implementato	Stesso endpoint /me/export in formato JSON strutturato e machine-readable
Cancellazione (art. 17)	■ Parziale	POST /checkup/me/deletion-request → email al DPO/admin. Cancellazione effettiva manuale (corretto per valutazione legale previa). Manca workflow automatizzato end-to-end.
Rettifica (art. 16)	■ Parziale	Il cliente può aggiornare le risposte tramite l'interfaccia di pre-assessment. Non esiste un endpoint dedicato alla rettifica dei dati anagrafici da parte dell'interessato.
Opposizione (art. 21)	■ Da formalizzare	Non esiste un canale in-app per l'esercizio del diritto di opposizione. Va gestito via email al DPO.
Limitazione (art. 18)	■ Da formalizzare	Non implementato tecnicamente; gestibile tramite deactivate user + freeze manuale del preassessment.
Informativa (art. 13-14)	■ Verifica richiesta	Non rilevata nell'interfaccia frontend una privacy notice/informativa GDPR al momento del login o della prima registrazione. Deve essere predisposta dal licenziatario.

4. Analisi dei Rischi

4.1 Metodologia

La valutazione del rischio adotta la metodologia **ENISA Threat Landscape 2024** combinata con la matrice di probabilità × impatto in scala 1-5. Il livello di rischio è classificato come:

Livello	Punteggio P×I	Descrizione
BASSO	1–4	Rischio accettabile; misure di controllo adeguate in essere
MEDIO	5–9	Rischio da monitorare; possibili miglioramenti raccomandati
ALTO	10–25	Rischio significativo; misure aggiuntive necessarie prima del go-live in produzione

Legenda colonne: **P** = Probabilità (1=molto bassa ... 5=molto alta); **I** = Impatto (1=trascurabile ... 5=critico). Il livello residuo è calcolato *dopo* l'applicazione delle misure di mitigazione identificate.

4.2 Registro dei rischi identificati

Trattamento	Minaccia / Vulnerabilità	P	I	Livello	Misure di mitigazione
Autenticazione utente	Credential stuffing / brute force sulle credenziali di accesso	2	4	BASSO	Rate limiting 5 req/15min su /auth/login; account lockout dopo 10 tentativi in 15 min; 2FA obbligatorio
Token di sessione (JWT)	Furto del refresh token via XSS o intercettazione di rete	2	4	BASSO	Cookie httpOnly + SameSite=Strict; refresh token blacklist in Redis; access token valido solo 1h
Dati del questionario (campo data)	Accesso non autorizzato al DB → esposizione dati di assessment	2	5	MEDIO	Cifratura AES-256-GCM a livello di colonna con chiave separata (CHECKUP_BACKUP_ENCRYPTION_KEY); accesso DB limitato all'utente rc_user
Dati del questionario (campo data)	Perdita della chiave di cifratura → impossibilità di decifrare i dati	1	5	MEDIO	Chiave configurabile via env; raccomandato backup sicuro separato della chiave e rotazione periodica
File allegati	Upload di file malevolo (malware, web shell, file con macros)	2	4	BASSO	Whitelist MIME; validazione magic bytes; UUID filename; max 30 MB; nessuna esecuzione server-side
File allegati	Accesso non autorizzato ai file da parte di altri tenant	2	4	BASSO	Ogni download passa per l'endpoint autenticato con verifica proprietà preassessment; nessun URL pubblico
Trasmissione email (SMTP)	Intercettazione e-mail 2FA / reset password in transito	2	3	BASSO	TLS via SMTP_SECURE; codici OTP con TTL breve; token one-time

Trattamento	Minaccia / Vulnerabilità	P	I	Livello	Misure di mitigazione
Trasmissione email (SMTP)	Configurazione SMTP errata → invio codici a destinatari sbagliati	1	4	BASSO	Configurazione a livello di env; raccomandato test SMTP in staging; logging errori SMTP
Audit log	Cancellazione o manomissione dei log prima del termine di conservazione	1	4	BASSO	Cron automatica di cancellazione (03:00); accesso limitato agli admin; log immutabili (no UPDATE/DELETE manuale esposto)
Dati di backup	Accesso non autorizzato ai backup del database	2	5	MEDIO	Backup cifrati AES-256-GCM; chiave separata dal DB; raccomandato off-site storage con access control
Presenza real-time (in-memory)	Memory exhaustion / DoS per flooding di heartbeat	2	3	BASSO	Mappa capped a 10.000 entry; cleanup ogni 5 min; rate limit 30 req/min sull'endpoint
Multi-tenancy (sublicenze)	Un tenant accede ai dati di un altro tenant per misconfiguration	1	5	MEDIO	Ogni query service verifica la catena studio → sublicenza → client; guard RBAC su ogni endpoint; test di isolamento consigliati
Export dati personali (me/export)	Enumerazione / abuso dell'endpoint di export da parte di script automatizzati	2	3	BASSO	Rate limit 5 req/ora; richiede JWT valido dell'interessato stesso
Gestione 2FA (DB)	Enumerazione codici OTP via timing attack sul DB	2	3	BASSO	Codice challenge opaco in Redis (UUID random, non user-ID); TTL 5 min; eliminato al primo uso
Conservazione oltre il necessario	Dati di assessment non anonimizzati oltre i 365 giorni	1	4	BASSO	Cron automatica (04:00) con cancellazione file fisici e azzeramento campi sensibili; configurabile via env
Informativa agli interessati	Interessati non informati del trattamento al momento della raccolta	3	4	ALTO	Non rilevata privacy notice in-app. Il licenziatario DEVE esporre informativa ex art. 13 GDPR prima della raccolta dei dati. Punto aperto da sanare con priorità alta.
Diritto di rettifica / opposizione	Impossibilità dell'interessato di esercitare i propri diritti in autonomia	2	3	MEDIO	Attualmente gestito via email/DPO. Raccomandato aggiungere sezione self-service in SettingsPage per rettifica dati anagrafici.
Presenza real-time	Rilevazione dell'attività dell'utente in tempo reale da parte di operatori	2	2	BASSO	Solo staff autorizzato può vedere la mappa di presenza; nessuna persistenza su disco; accesso RBAC verificato

4.3 Riepilogo del livello di rischio residuo

Livello	N. rischi identificati	N. rischi residui	Valutazione
ALTO	1	1 (aperto)	Richiede azione immediata da parte del licenziatario (informativa GDPR)

Livello	N. rischi identificati	N. rischi residui	Valutazione
MEDIO	5	3 (parzialmente mitigati)	Misure aggiuntive raccomandate entro 90 giorni
BASSO	12	0 (mitigati)	Rischio accettabile; controlli in essere adeguati

5. Misure di Sicurezza Adottate

5.1 Autenticazione e controllo degli accessi

Il modulo implementa un sistema di autenticazione a più livelli conforme alle best practice OWASP Authentication Cheat Sheet e alle prescrizioni dell'art. 32(1)(b) GDPR:

- **Password hashing:** bcrypt con salt generato automaticamente; nessun storage in plaintext.
- **JWT dual-token:** access token (exp. 1h, in localStorage) + refresh token (exp. 7gg, httpOnly cookie SameSite=Strict); secret separati dal modulo principale.
- **Refresh token rotation:** alla rotazione, il token precedente viene aggiunto alla blacklist Redis con TTL 7gg; replay attack non possibile.
- **2FA opzionale:** via email o SMS; challenge token opaco (UUID) in Redis con TTL 5 min; eliminato al primo uso per prevenire replay.
- **Account lockout:** 10 tentativi falliti in 15 min → blocco 15 min; contatore in Redis.
- **RBAC a 4 livelli:** superadmin / admin_studio / segreteria-collaboratore / cliente; guard applicati su ogni endpoint; validazione chain studio → sublicenza → client a livello service.

5.2 Cifratura dei dati

Campo data (questionario)	AES-256-GCM, cifratura/decifratura tramite TypeORM transformer personalizzato (createEncryptedJsonTransformer). IV casuale per ogni operazione di cifratura. Chiave: CHECKUP_BACKUP_ENCRYPTION_KEY (32 byte / 64 hex).
Campi note operative	Stessa cifratura AES-256-GCM applicata a: notes, fieldNotes, userFieldNotes, naFields, fieldMeta, macroValidations, sectionValidations, finalValidation.
Backup del database	mysqldump → pipe → AES-256-GCM; output: 16-byte IV + 16-byte AuthTag + ciphertext. Compatibile con decifratura separata dalla chiave DB.
Trasporto (in transit)	HTTPS obbligatorio in produzione (nginx con TLS); SMTP con STARTTLS/TLS.
Token Redis	Valori opachi (UUID); nessun dato sensibile in chiaro nelle chiavi Redis.

5.3 Sicurezza dei file e degli upload

- **Whitelist MIME type:** solo PDF, Word, Excel, PowerPoint, immagini (JPEG/PNG/GIF/WebP), CSV, testo. Nessun eseguibile (.exe, .sh, .js).
- **Validazione magic bytes:** il contenuto reale del file viene verificato contro la firma binaria del tipo dichiarato; previene file-extension spoofing.
- **Naming UUID:** il nome del file su disco è un UUID v4; nessuna path traversal possibile.
- **SHA-256 digest:** calcolato e persistito in DB per ogni upload; consente verifica di integrità post-upload.
- **Limite dimensione:** 30 MB per file; protezione da DoS storage.
- **Accesso autenticato:** ogni download richiede JWT valido + verifica che il preassessment appartenga all'utente o al suo studio.

5.4 Rate limiting e protezione endpoint

Endpoint	Limite	Finestra
POST /auth/login	5 req	15 min
POST /auth/login/2fa	5 req	15 min
POST /auth/password-reset/request	3 req	15 min
POST /auth/password-reset/confirm	5 req	15 min
GET /me/export	5 req	1 ora
POST /me/deletion-request	3 req	1 giorno
POST /preassessment/pdf/jobs	3 req	1 min
Presenza heartbeat	30 req	1 min
Tutti gli altri endpoint (fallback)	100 req	60 sec

5.5 Audit log e monitoraggio

Il sistema registra un log di audit completo (CheckupAuditLog) per tutte le operazioni sensibili. I log includono: userId, userEmail, userRole, azione (LOGIN, LOGOUT, LOGIN_FAILED, CREATE, UPDATE, DELETE, UPLOAD_FILE, DOWNLOAD_FILE, EXPORT_DATA, ecc.), entityType, entityId, indirizzo IP, user-agent, studioid, esito (success/error), messaggio di errore.

- L'interceptor è applicato globalmente; gli endpoint di presenza sono esclusi per evitare log spam (corretta scelta di proporzionalità).
- I log sono consultabili dagli admin_studio per il proprio tenant; i superadmin vedono tutto.
- Export CSV dei log disponibile per audit esterni.
- Cancellazione automatica dopo 90 giorni (cron 03:00); periodo estendibile via env.

5.6 Conservazione e cancellazione automatica

Il ciclo di vita del dato è governato da due servizi cron:

CheckupPreassessmentRetentionService	Cron: ogni giorno alle 04:00. Anonimizza i preassessment in stato 'concluso' con updatedAt più vecchio di CHECKUP_PREASSESSMENT_RETENTION_DAYS (default: 365). Azioni: azzera data/notes/fieldNotes/userFieldNotes/naFields/fieldMeta; elimina file fisici dal disco; marca documenti come attivo=false. Conserva: status, completedAt, macroValidations/sectionValidations per statistiche aggregate anonime.
CheckupAuditLogService (cron)	Cron: ogni giorno alle 03:00. Elimina (DELETE) i log di audit con createdAt più vecchio di CHECKUP_AUDIT_RETENTION_DAYS (default: 90). Nessun backup dei log cancellati.

6. Diritti degli Interessati (GDPR Art. 12–22)

In questa sezione si valuta lo stato di attuazione degli obblighi informativi e dei meccanismi per l'esercizio dei diritti previsti dagli articoli 12-22 del GDPR, con indicazione delle lacune riscontrate e delle azioni correttive raccomandate.

Punto critico — Informativa ex art. 13 GDPR: L'analisi del frontend non ha rilevato la presenza di una privacy notice o di un consenso informato mostrato all'utente al momento della registrazione o del primo accesso. Il licenziatario ha l'obbligo di predisporre e pubblicare l'informativa sul trattamento dei dati personali prima che i dati vengano raccolti. Questo punto costituisce il rischio ALTO identificato nella Sezione 4.

Raccomandazioni operative per il licenziatario

- **Informativa GDPR (art. 13):** pubblicare la privacy policy raggiungibile dalla schermata di login; mostrare un banner/checkbox al primo accesso del cliente finale.
- **Rettifica dati anagrafici (art. 16):** aggiungere alla SettingsPage un form per la modifica autonoma di nome, cognome, telefono da parte dell'interessato.
- **Opposizione e limitazione (artt. 18, 21):** formalizzare il processo via email al DPO con SLA massima di risposta (si raccomanda 30 giorni); documentare il processo nel Registro dei Trattamenti.
- **Registro dei trattamenti (art. 30):** il licenziatario deve tenere un proprio registro dei trattamenti che comprenda il Modulo Checkup come attività di trattamento.
- **Accordo responsabile del trattamento (art. 28):** il contratto tra Resolv S.r.l. e i licenziatari deve contenere le clausole ex art. 28 GDPR (DPA — Data Processing Agreement), specificando obblighi, sub-responsabili e misure di sicurezza.

7. Trasferimenti verso Terze Parti

Nella configurazione standard analizzata, le terze parti coinvolte nel trattamento dei dati personali sono le seguenti:

Soggetto terzo	Ruolo GDPR	Tipologia dato trasferito	Garanzie / Note
Provider SMTP (es. Gmail, SendGrid, Mailgun)	Responsabile del trattamento (art. 28)	Indirizzo email destinatario, codice OTP, link reset password	DPA necessario; verificare localizzazione server. Se extra-UE: Standard Contractual Clauses (SCC) obbligatorie.
Provider hosting / VPS (server applicativo)	Responsabile del trattamento (art. 28)	Tutti i dati in transito e at-rest sul server	DPA necessario; preferire hosting UE/SEE; verificare certificazioni ISO 27001.
Provider database MySQL/MariaDB (se managed)	Responsabile del trattamento (art. 28)	Tutti i dati del DB (inclusi dati cifrati)	DPA necessario; crittografia at-rest del volume consigliata a livello infrastrutturale.
Provider Redis (se managed)	Responsabile del trattamento (art. 28)	Token di sessione, contatori lockout (dato tecnico pseudonimizzato)	DPA se managed; dati tecnici senza PII diretta. TTL brevi limitano l'esposizione.

Nota sul trasferimento extra-UE: Se il provider SMTP (es. Gmail/Google, SendGrid) ha infrastruttura negli USA, il trasferimento di indirizzi email è soggetto alle disposizioni del Capo V GDPR. In assenza del Data Privacy Framework EU-US applicabile e di SCC firmate, il trasferimento potrebbe essere non conforme. Si raccomanda di verificare e documentare la base giuridica per ogni trasferimento internazionale.

8. Consultazione del DPO

Ai sensi dell'art. 35(2) GDPR, il titolare del trattamento è tenuto a consultare il Responsabile della Protezione dei Dati (DPO) prima di procedere con il trattamento, qualora sia stato designato. La presente sezione documenta lo stato della consultazione.

DPO di Resolv S.r.l.	Da nominarsi / verificare designazione ai sensi dell'art. 37 GDPR. Se il trattamento è effettuato su larga scala, la nomina è obbligatoria.
Parere DPO su questa DPIA	Da acquisire formalmente dopo la presentazione della bozza DPIA. Il DPO deve esprimere parere scritto entro un termine ragionevole.
DPO del licenziatario	Il licenziatario che adotta il Modulo Checkup deve valutare autonomamente l'obbligo di designazione del DPO in funzione del proprio volume di trattamento.
Consultazione preventiva (art. 36)	Qualora le misure di mitigazione non siano sufficienti a ridurre il rischio ALTO (informativa GDPR mancante), il titolare è tenuto a consultare l'Autorità di Controllo (Garante Privacy italiano) prima dell'avvio del trattamento.

Azione richiesta: Prima del rilascio in produzione agli utenti finali, Resolv S.r.l. deve: (1) verificare o procedere alla nomina del DPO; (2) sottoporre la presente DPIA al DPO per parere; (3) acquisire il parere per iscritto e allegarlo a questo documento come Appendice C. In assenza del DPO, consultare il Garante Privacy ai sensi dell'art. 36 GDPR.

9. Rischi Residui e Piano di Miglioramento

La tabella seguente riepiloga i rischi che non sono stati completamente mitigati dalla configurazione attuale, con indicazione della priorità, del responsabile dell'azione e della scadenza raccomandata.

ID	Rischio residuo	Azione raccomandata	Priorità	Responsabile	Scadenza
R-01	Informativa GDPR assente in-app	Implementare privacy notice al login e banner consenso al primo accesso	ALTA	Licenziatario + Resolv S.r.l.	Immediata
R-02	DPA con provider SMTP non verificato	Censire il provider SMTP; firmare DPA; verificare trasferimenti extra-UE e SCC	ALTA	Resolv S.r.l.	30 giorni
R-03	Backup chiave cifratura non gestita	Definire procedura di backup e rotazione della CHECKUP_BACKUP_ENCRYPTION_KEY; considerare KMS (Key Management Service)	MEDIA	Resolv S.r.l.	60 giorni
R-04	Multi-tenancy: test di isolamento non documentati	Implementare e documentare test automatici di isolamento tenant (integration tests)	MEDIA	Resolv S.r.l.	60 giorni
R-05	Diritto di rettifica non self-service	Aggiungere form di modifica dati anagrafici in SettingsPage; processo interno per le richieste	MEDIA	Resolv S.r.l.	90 giorni
R-06	Presenza in-memory non distribuita	Migrare mappa di presenza su Redis per supporto multi-instance deployment	BASSA	Resolv S.r.l.	180 giorni
R-07	DPO non designato / parere DPO mancante	Valutare obbligo di nomina DPO; acquisire parere scritto su questa DPIA	ALTA	Resolv S.r.l.	30 giorni
R-08	Cancellazione richiesta diritto oblio non automatizzata end-to-end	Implementare workflow interno documentato con SLA; considerare automazione parziale (deactivate + anonimizzazione forzata)	MEDIA	Resolv S.r.l.	90 giorni

10. Conclusioni e Parere dell'Auditor

Giudizio complessivo

All'esito dell'analisi condotta, il Modulo Checkup della piattaforma Resolv presenta un livello di maturità tecnica in materia di protezione dei dati **medio-alto**, con importanti misure di sicurezza già implementate e conformi alle prescrizioni dell'art. 32 GDPR.

Punti di forza rilevati

- Cifratura a livello di colonna (AES-256-GCM) per tutti i dati sensibili del questionario: approccio avanzato, raro nei SaaS di questa categoria.
- Sistema di autenticazione robusto: JWT dual-token, refresh token blacklist, 2FA opaco, account lockout — stack difensivo coerente e ben progettato.
- Validazione magic bytes dei file allegati: misura tecnica efficace contro file-type spoofing.
- Cancellazione automatica con cron pianificate: ottima implementazione del principio di limitazione della conservazione (art. 5(1)(e) GDPR).
- Audit log granulare con retention configurabile: consente tracciabilità degli accessi e supporto a eventuali indagini su data breach.
- Endpoint self-service per export (art. 20) e richiesta cancellazione (art. 17): dimostrano sensibilità verso i diritti degli interessati.
- Rate limiting capillare su tutti gli endpoint sensibili: protezione efficace contro brute force e abusi.
- Isolamento multi-tenant a livello di servizio (chain studio → sublicenza → client): architettura corretta per SaaS multitenancy.

Aree di miglioramento prioritarie

- **[ALTA — Immediata]** Pubblicazione informativa GDPR ex art. 13 accessibile dall'interfaccia prima della raccolta dei dati.
- **[ALTA — 30 gg]** Nomina DPO o consulenza DPO esterno; acquisire parere formale su questa DPIA.
- **[ALTA — 30 gg]** Verifica e firma DPA con il provider SMTP; verifica trasferimenti extra-UE.
- **[MEDIA — 60 gg]** Procedura di gestione della chiave di cifratura (backup, rotazione, KMS).
- **[MEDIA — 60 gg]** Test automatici di isolamento tenant.
- **[MEDIA — 90 gg]** Self-service rettifica dati e workflow diritto all'oblio.

Parere dell'Auditor

PrivacyAudit Italia S.r.l. esprime **parere favorevole condizionato** alla messa in produzione del Modulo Checkup, subordinato alla risoluzione delle non conformità ad alto rischio (R-01, R-02, R-07) entro i termini indicati nel Piano di Miglioramento (Sezione 9). Le non conformità a medio rischio (R-03, R-04, R-05, R-08) devono essere risolte entro 90 giorni dall'avvio della produzione e documentate in un follow-up audit da condursi entro 6 mesi dalla presente valutazione. Il presente documento deve essere aggiornato ogni qualvolta intervengano modifiche sostanziali al trattamento (nuovo tipo di dato, nuova finalità, nuova tecnologia) e comunque con revisione annuale.

Lead Auditor	Dott.ssa Francesca Conti, CIPP/E, CIPM — PrivacyAudit Italia S.r.l.
Data firma	13 Marzo 2026
Prossima revisione	13 Marzo 2027 (o prima in caso di modifiche sostanziali)
Versione documento	1.0 — DEFINITIVO
Distribuzione	Resolv S.r.l. (originale); Clienti Licenziatari (copia anonimizzata fornita da Resolv S.r.l.)

App. A. Mappa delle Entità del Database

Le seguenti tabelle con prefisso checkup_ sono presenti nel database MySQL della piattaforma:

Tabella	Entità principale	Dati personali	Cifratura
checkup_users	Utenti del modulo	email, nome, cognome, telefono, password hash, 2FA code	Password: bcrypt Altri: no cifratura colonna
checkup_clients	Clienti finali (aziende)	ragioneSociale, P.IVA, CF, indirizzo, email, telefono	No cifratura colonna
checkup_studios	Studi licenziatari	ragioneSociale, P.IVA, CF, indirizzo, email, telefono	No cifratura colonna
checkup_preassessments	Questionari compilati	data (risposte), notes, fieldNotes, userFieldNotes, naFields, fieldMeta, macroValidations, sectionValidations, finalValidation	AES-256-GCM su tutti i campi dati sensibili
checkup_preassessment_documents	File allegati	nomeOriginale, caricatoDa, sha256, percorsoFile	No cifratura colonna; file cifrati non in-situ
checkup_tickets / checkup_ticket_messages	Ticket supporto e risposte	subject, body, messaggio (testo libero)	No cifratura colonna
checkup_alerts	Alert/notifiche	messaggio (testo libero), targetUserId	No cifratura colonna
checkup_preassessment_messages	Chat per sezione	messaggio (testo libero), userId	No cifratura colonna
checkup_audit_logs	Log di audit	userId, userEmail, userRole, ipAddress, userAgent	No cifratura colonna; pseudonimizzato per IP
checkup_reports	Report PDF generati	reportPath, fileName (nome file)	File non cifrati in-situ
checkup_licenses / checkup_sublicenses	Licenze e sublicenze	Dati contrattuali, ID studi	No cifratura colonna

Osservazione: I campi di testo libero in checkup_tickets, checkup_alerts e checkup_preassessment_messages non sono cifrati a livello di colonna. Considerata la potenziale sensibilità delle comunicazioni interne, si raccomanda di valutare l'estensione della cifratura AES-256-GCM anche a questi campi in una release futura.

App. B. Registro dei Trattamenti — Estratto (Art. 30 GDPR)

Il presente estratto è fornito a titolo di supporto per la compilazione del Registro dei Trattamenti del licenziatario. Non sostituisce il registro ufficiale che deve essere tenuto e aggiornato dal titolare del trattamento.

Voce (art. 30)	Contenuto
Nome del trattamento	Pre-valutazione clienti tramite Modulo Checkup — Piattaforma Resolv
Titolare del trattamento	[Nome dello Studio Licenziatario] — [Indirizzo] — [email] — [P.IVA]
Finalità del trattamento	Raccolta e analisi di informazioni organizzative, di compliance e di sicurezza dei clienti finali ai fini della valutazione e consulenza professionale.
Categorie di interessati	Clienti finali (persone fisiche o referenti di persone giuridiche); Personale dello studio.
Categorie di dati personali	Dati identificativi e di contatto; dati organizzativi e di compliance; documenti allegati; log di accesso.
Categorie di destinatari	Resolv S.r.l. (fornitore piattaforma, responsabile ex art. 28); provider SMTP; provider hosting.
Trasferimenti verso Paesi terzi	Eventuale trasferimento al provider SMTP (verificare); in tal caso: SCC o altro meccanismo di garanzia ex artt. 46-47 GDPR.
Termini di cancellazione	Dati del questionario: anonimizzazione automatica dopo 365 giorni dalla conclusione. Log di audit: cancellazione dopo 90 giorni. Dati anagrafici utenti: alla cessazione del rapporto contrattuale.
Misure di sicurezza tecniche	Cifratura AES-256-GCM dei dati del questionario; TLS in transito; 2FA; audit log; backup cifrati; controllo accessi RBAC; rate limiting.
Base giuridica	Art. 6(1)(b) GDPR — Esecuzione del contratto; art. 6(1)(f) — Legittimo interesse per sicurezza e audit.

Il presente documento è stato redatto da **PrivacyAudit Italia S.r.l.** su incarico di Resolv S.r.l. Ogni riproduzione, distribuzione o utilizzo non autorizzato è vietato. Il documento è classificato **RISERVATO**. La versione per i clienti licenziatari deve essere consegnata da Resolv S.r.l. previa rimozione di eventuali informazioni tecniche riservate indicate con [OMISSIS].